

■ AIエージェント／セキュリティ

自律型AIが漏洩トークン発見 25分で本番環境の管理者権限に到達

公開Dockerイメージのメタデータが原因

セキュリティ企業Strixが、自社の自律型ハッキングエージェントをBasetenの公開インフラに向けて検証した。エージェントは公開Harborレジストリを発見し、2023年3月ビルドの古いDockerイメージをダウンロード、ビルド履歴に残っていたGitHub個人ア

クセストークンをTruffleHogで検出した。権限を読み取り専用で確認したところ、トークンはメイン製品リポジトリ・本番インフラ管理用のGitOpsリポジトリ・顧客専用リポジトリへのadmin/push権限を保持していた。ホスト列挙から権限確認まで、人手を介さず約25分で完了した。

原因は、プライベート依存関係取得のためビルド引数として渡したトークンが、Dockerによりイメージのメタデータに記録されてしまう一般的なパターン。Basetenは報告翌日にトークンを無効化・ローテーションし、9月に公開開示した。



自律型AIエージェントが25分で本番環境の管理者権限に到達した事例

出典 [Strix Security Blog](#)

数字で見る

25分

調査開始から権限確認まで

2023年

漏洩トークンを含むイメージのビルド年

3系統

到達した本番リポジトリ

■ AI安全性／ベンチマーク・査読前

自殺念慮など高リスク会話でLLM評価 臨床医監修のK-Bench登場

33基本モデル・14プロバイダー・125モデル構成を、模擬患者との対話で評価。151件の臨床医評価トランスクリプトから6,751件を比較し、GPT-4o自動判定と臨床医の一致率は94.2%だった。推論能力を上げても安全性は平均的に改善せ



ず、治療的プロンプティングの効果もモデル間でばらついた。

出典 [arXiv（査読前）](#)

■ オープンソース／査読前

「AIスロップ」がOSSを飽和攻撃 初回貢献者のマージ率18.18%低下

294リポジトリ・200万件超のPR/issueをベイズ構造時系列分析。2025年にPR投稿数は増加した一方、初めて貢献する開発者のマージ率は反実仮想比で18.18%低下した。日経クロステックも9/16付で「1日200件の変更提



案」に悩むメンテナー実例を報じている。

出典 [arXiv（査読前）](#)

短 信

〈AI評価／方法論〉**MMLUSコアは同名でも比較不能**

実装差でllama-65bが0.637/0.488/0.636と変動。

出典 [zatona.dev](#)

〈モデル発表〉**Gemini 3.8 Live発表**

音声品質指数82.6、Big Bench Audio 97.7%。

出典 [Google Blog](#)

〈インフラ〉**推論ハードウェアに投資集中**

H100は稼働の50-80%がアイドル。新設計相次ぐ。

出典 [IEEE Spectrum](#)

〈セキュリティ〉**運転免許証153万件分が漏洩**

身分確認企業から流出。国家安全保障上の懸念が指摘された。

出典 [Lawfare](#)

〈モデル発表〉**新アーキテクチャ「Jev」発表**

応答70～500ms、幻覚ゼロを主張する意思決定特化モデル。

出典 [typesafe.ai](#)

〈医療AI／査読前〉**LLMで調査データを分割学習統合**

2000サンプルでANLS0.708、計算量を3桁削減。

出典 [arXiv](#)

〈AI悪用対策〉**大手AI企業が脅威情報を公開**

2025年12月～2026年8月、7分野の不正利用を遮断と報告。

出典 [脅威インテリジェンスレポート](#)

〈AI安全性〉**「見られていない時」のAI評価は困難に**

研究者個人が状況認識の高まりへの懸念を表明。

出典 [個人声明\(researcher statement\)](#)